

OLAY MÜDAHALE RAPORU

Incident Response Report

CyberTech A.Ş. - SOC Simülasyon Ortamı

Hazırlayan	Arzum Enfal Kulaksız
Rapor Tarihi	Nisan 2026
Kapsam	Mindset Institute Bootcamp & Independent SOC Lab Simülasyonu
Sınıflandırma	TLP: CLEAR (Public / Lab Simülasyonu)
Uygulanan Çerçeve	NIST SP 800-61 Rev.3 MITRE ATT&CK v15 NIST CSF 2.0
Hedef Sistemler	192.168.1.95 (Windows 10) 192.168.1.93 (Metasploitable 2)
SIEM / İzleme	Wazuh 4.x SIEM (192.168.1.50) + Suricata NIDS (192.168.1.46)

Bu rapor NIST SP 800-61 Rev.3 (Computer Security Incident Handling Guide) olay müdahale yaşam döngüsüne göre yapılandırılmıştır.

YÖNETİCİ ÖZETİ

Executive Summary

Bu rapor, CyberTech A.Ş. SOC simülasyon ortamında 08-31 Mart 2026 tarihleri arasında gerçekleştirilen kırmızı takım saldırılarını tek bir olay kaydı altında birleştirir ve NIST SP 800-61 olay müdahale yaşam döngüsüne (Hazırlık → Tespit ve Analiz → Kapsama/Ortadan Kaldırma/Kurtarma → Olay Sonrası Faaliyet) göre belgeler. Rapor, ağırlıklı olarak Wazuh SIEM ve Suricata NIDS'in saldırı zincirine verdiği yanıtların analizine odaklanır.

İki hedef sistemde eş zamanlı olarak yürütülen saldırılar sonucunda Windows 10 hedefinde (192.168.1.95) Pass-the-Hash ve PsExec ile SYSTEM seviyesinde yetki ele geçirilmiş, Metasploitable 2 hedefinde (192.168.1.93) vsftpd backdoor'u ile root shell elde edilip /etc/shadow dosyası exfiltrate edilmiştir. Olayın genel önem derecesi KRİTİK olarak sınıflandırılmıştır.

SIEM görünürlüğü açısından 11 saldırı fazından 10'u Wazuh/Suricata tarafından başarıyla tespit edilmiş; en yüksek seviyeli alarmlar Pass-the-Hash (Rule 100080, Level 14) ve PsExec Hidden PowerShell Service (Rule 100082, Level 14) olarak kaydedilmiştir. Tek görünürlük boşluğu, host dışında gerçekleştirilen John the Ripper offline hash kırma işlemidir; bu husus Tespit Boşlukları bölümünde ayrıntılandırılmıştır.

Bu rapor, CyberTech A.Ş. SOC simülasyon ortamında gerçekleştirilen penetrasyon testlerine ait teknik kanıt ve saldırı detaylarını içeren "Pentest & SIEM Analiz Raporu" na dayanmaktadır. Teknik saldırı adımları, komutlar ve SIEM tespitlerine ait görsel kanıtlar ilgili raporda detaylandırılmıştır; bu belge NIST SP 800-61 Olay Müdahale yaşam döngüsüne göre yapılandırılmıştır.

Yasal Yükümlülükler: KVKK (72 saat), GDPR (72 saat), BDDK (derhal) bildirim süreçleri gözetilmelidir.

Olay Sınıflandırması (NIST SP 800-61)

Kriter	Değerlendirme	Açıklama
Fonksiyonel Etki	Yüksek	SYSTEM/root seviyesinde tam sistem ele geçirme, iş sürekliliğini etkileyebilecek düzeyde yetki kazanımı.
Bilgi Etkisi	Özel/Ayrıcalıklı Bilgi ihlali	Kimlik bilgileri (NTLM hash, /etc/shadow), veritabanı bilgileri sızdırıldı.
Kurtarılabirlik	Öngörülebilir Süre İçinde	Kapsama ve yama uygulamalarıyla ortam standart prosedürlerle kurtarılabir.
Genel Önem Derecesi	KRİTİK	Çoklu, zincirleme, kimlik doğrulama atlatma ve veri sızıntısı içeren olay.

OLAY ZAMAN ÇİZELGESİ

Combined Incident Timeline - Windows 10 & Metasploitable 2

Tarih/Saat	Faz	Olay	Önem	SIEM/Wazuh Kanıtı
08-23 Mar	Keşif	Nmap port taraması (445, 21 dahil 20+ port)	ORTA	100031 / 100061 / 100041
23 Mar	İlk Erişim (Windows)	NetExec SMB Brute-Force → Administrator:1234567	KRİTİK	100026
24-25 Mar	İlk Erişim (Metasploitable)	vsftpd 2.3.4 backdoor (CVE-2011-2523) → root shell, port 6200	KRİTİK	100047
25 Mar	Exfiltration	/etc/shadow dosyası indirildi	KRİTİK	100047 / FIM (offline)
26 Mar	Credential Access	John the Ripper ile offline hash kırma (3 hesap)	KRİTİK	SIEM'de görünmedi
27-28 Mar	İlk Erişim (Web)	DVWA üzerinde Union/Error-based SQL Injection	YÜKSEK	100050 / 100051
30 Mar 1:30 - 1:45	Savunma Atlama (Windows)	UAC Bypass, Defender Kapatma, Reboot	YÜKSEK	(Event Viewer) ID 5007, 10074
30 Mar	Credential Access	NetExec --sam/--lsa ile 6 NTLM hash elde edildi	KRİTİK	LSASS Alert / 92652
30 Mar 02:13	Yanal Hareket	Psexec servis kaydı oluşturuldu (61138)	YÜKSEK	61138
31 Mar 03:09-03:11	Yanal Hareket	Pass-the-Hash doğrulaması, Administrator NTLM ile SMB oturumu	KRİTİK	100080 (v1/v2)
31 Mar 04:10	Yanal Hareket	Psexec ile SYSTEM shell + Evil-WinRM oturumu	KRİTİK	100082
31 Mar	Exfiltration	SAM/LSA dump, DPAPI key'leri exfil edildi	KRİTİK	Tespit edildi

Not: Tabloda kritiklik yalnızca metin olarak belirtilmemiş, renk kodlaması ile de vurgulanmıştır (Kırmızı: Kritik, Turuncu: Yüksek, Sarı: Orta).

TESPİT VE ANALİZ - SIEM ANALİZİ

Bu bölüm NIST SP 800-61'in "Detection & Analysis" fazına karşılık gelir ve raporun ana odak noktasıdır. Her saldırı adımı, ilgili MITRE ATT&CK tekniği ve Wazuh/Suricata kural kimliğiyle eşleştirilmiştir.

4.1 Windows 10 Saldırı Zinciri - SIEM/Wazuh Korelasyonu

#	Faz	Teknik / Olay	MITRE ATT&CK	Rule ID	Level	SIEM Tespiti
1	Keşif	Nmap Port 445 taraması	T1046 Network Service Scanning	100031	6	Var
2	İlk Erişim	NetExec SMB Brute-Force (Admin:1234567)	T1110 Brute Force	100026	12	Var
3	Savunma Atlama	UAC Bypass, Defender Kapatma, Reboot	T1548.002, T1562.001, T1529	Event ID 5007, 1074	-	Event Viewer'da Görüldü
4	Credential Access	NetExec --sam/--lsa + John the Ripper	T1003 OS Credential Dumping	LSASS Alert	10	Kısmi (offline kırma görünmedi)
5	Yanal Hareket	Psexec servis kaydı	T1543.003 Windows Service	61138	5	Var
6	Yanal Hareket	Pass-the-Hash doğrulaması	T1550.002 Pass-the-Hash	100080 (v1/v2)	14 / 12	Var
7	Yanal Hareket	Psexec Hidden PowerShell Service + Evil-WinRM	T1569.002 / T1021.006	100082	14	Var

31 Mart 2026 03:11:05'te Wazuh, özel yazılan 100080* (v1) kuralı ile Pass-the-Hash saldırısını Level 14 önemde tespit etmiştir; ardından 04:10:30'da PsExec Hidden PowerShell Service faaliyeti Rule 100082 (Level 14) ile işaretlenmiştir. Bu iki alarm, projenin en kritik SOC görünürlük kanıtlarıdır. LSASS bellek erişimi doğrudan alarm üretmemiş, tespit NTLM logon anomalisi (keyLength=0, Logon Type) üzerinden dolaylı olarak sağlanmıştır.

4.2 Metasploitable 2 Saldırı Zinciri — SIEM/Wazuh + Suricata Korelasyonu

#	Faz	Teknik / Olay	MITRE ATT&CK	Rule ID	Level	SIEM Tespiti
1	Keşif	Nmap -sV (vsftpd 2.3.4 tespiti)	T1046 / T1595.002	100061 / 100062	8	Var
2	Exploit	MSF vsftpd_234_backdoor (CVE-2011-2523)	T1190 Exploit Public-Facing App.	100047	12	Var
3	Credential Access	/etc/shadow exfiltration	T1552 / T1005	100047 (transfer üzerinden)	12	Var
4	Credential Access	John the Ripper offline hash kırma	T1110.002 Password Cracking	—	—	Yok (host-dışı işlem)
5	İlk Erişim (Web)	DVWA SQL Injection (Union/Error-based)	T1190 / T1505.003	100050 / 100051	12	Var

Kaynak IP: 192.168.1.75 (Kali Linux) · Hedef: 192.168.1.93 (Metasploitable 2) · Araçlar: Metasploit, John the Ripper, DVWA

Suricata NIDS, vsftpd_234_backdoor exploit girişimini Rule 100047 (Level 12) ile ve DVWA üzerindeki SQL Injection denemelerini Rule 100050/100051 (Level 12) ile başarıyla tespit etmiştir. Buna karşın, indirilen /etc/shadow dosyasının host dışında John the Ripper ile kırılması SIEM'in görüş alanı dışında kalmıştır.

4.3 Tespit Boşlukları (Detection Gaps)

Boşluk	Kök Neden / Açıklama	Önerilen Ek Kontrol
Offline hash kırma (JtR)	İşlem host dışında (analist iş istasyonunda) gerçekleşti; Wazuh/Suricata kapsam alanı dışında kaldı.	FIM (File Integrity Monitoring) ile shadow dosyası erişim/okuma izlenmeli; DLP çözümü ile dosya çıkışı kontrol edilmeli.
LSASS bellek erişimi (PtH öncesi)	RunAsPPL/LSA Protection aktif olmadığından bellek erişimi SIEM tarafında doğrudan alarm üretmedi; tespit dolaylı yoldan (NTLM logon anomalisi) sağlandı.	Sysmon Event ID 10 (ProcessAccess) ile LSASS erişimleri izlenmeli, LSASS RunAsPPL etkinleştirilmeli.

4.4 MITRE ATT&CK Kapsam Haritası

Taktik	Teknik ID	Gözlemlenen Aktivite	Tespit Durumu	İlgili Rule ID
Reconnaissance	T1595.002 / T1046	Nmap Port/Service Scan	Tespit Edildi	100031 / 100061 / 100062 / 100041
Initial Access	T1110 / T1190	SMB Brute-Force, vsftpd exploit, SQLi	Tespit Edildi	100026 / 100047 / 100050 / 100051
Credential Access	T1003 / T1552 / T1110.002	LSASS dump, shadow exfil, offline crack	Kısmi Tespit	LSASS Alert (kısmi) / offline aşama görünmüyor
Persistence	T1543.003	Psexec Windows Service oluşturma	Tespit Edildi	61138
Lateral Movement	T1550.002 / T1569.002 / T1021.006	Pass-the-Hash, PsExec, Evil-WinRM	Tespit Edildi	100080 / 100082
Exfiltration	T1003.002 / T1555 / T1005	SAM/LSA dump, shadow dosyası	Tespit Edildi	Wazuh Tespiti / 100047

Kapsam haritası, olay boyunca kullanılan tüm taktik ve tekniklerin Wazuh/Suricata tarafındaki görünürlüğünü özetler.

KAPSAMA, ORTADAN KALDIRMA VE KURTARMA

Containment, Eradication & Recovery

Kapsama (Containment)

- **Kısa Vadeli:** Saldırgan IP'si (192.168.1.75) ile ilişkili trafik için geçici erişim engeli uygulanmalı; SOC prosedüründe otomatik kaynak IP engelleme kuralı devreye alınmalı.
- **Kimlik Bilgisi İzolasyonu:** Ele geçirilen Administrator hesabı ve tüm zayıf/varsayılan hesaplar (msfadmin, sys, klog) devre dışı bırakılmalı ve parolalar sıfırlanmalı.
- **Sistem İzolasyonu:** PsExec ile oluşturulan servis kaydı ve Evil-WinRM oturumları sonlandırılmalı, ilgili süreçler analiz için imaj alınarak kapatılmalı.
- **Kanıt Koruma:** Etkilenen sistemlerin snapshot/forensik imajı alınmalı; chain of custody belgelenmeli; loglar değiştirilmeden arşivlenmeli.
- **İletişim:** Olay bildirimleri şifreli kanallar üzerinden yapılmalı; dış bildirimler (KVKK, GDPR, BDDK) CISO ve Hukuk Danışmanı koordinasyonunda gerçekleştirilmelidir.

Ortadan Kaldırma (Eradication)

- **Zafiyet Giderme:** vsftpd 2.3.4 güncellenmeli veya kapatılmalı; DVWA/web katmanı yamalı sürüme taşınmalı ya da izole ortamda tutulmalı.
- **Yapılandırma Düzeltmesi:** SMB Signing zorunlu hale getirilmeli, SMBv1 protokolü tamamen devre dışı bırakılmalı.
- **Bellek Koruması:** LSASS RunAsPPL/LSA Protection etkinleştirilerek bellekten kimlik bilgisi çalınması engellenmeli.

Kurtarma (Recovery)

- **Sistem Restorasyonu:** Etkilenen sistemler temiz imajdan yeniden kurulmalı veya bütünlük doğrulaması sonrası servise alınmalı.
- **Politika Uygulaması:** Parola politikası (min. 20/12 karakter + karmaşıklık) tüm hesaplara uygulanmalı ve uyumluluk doğrulanmalı.

KÖK NEDEN ANALİZİ: POLİTİKA vs. UYGULAMA

Root Cause — Policy vs. Practice

Bu olay, teknik güvenlik araçlarının (SIEM, NIDS) ne kadar iyi yapılandırılmış olursa olsun, politika uygulamasındaki açıkların savunmayı geçersiz kılabileceğini somut biçimde göstermiştir.

Politika	Politika Gereği	Gözlem	Durum
Şifre Politikası	Yönetici hesabı min. 20 karakter, standart kullanıcı min. 12 karakter + karmaşıklık	Administrator:1234567 (7 haneli sayı); msfadmin:msfadmin; sys:batman; klog:123456789	KRİTİK
Erişim Kontrolü	SMB Signing zorunlu, SMBv1 kapalı	signing:False + SMBv1:True → Pth doğrudan mümkün	KRİTİK
Bellek Koruması	LSASS RunAsPPL / LSA Protection aktif olmalı	RunAsPPL etkin değil, LSASS'tan hash çalınabildi	YÜKSEK
Web Uygulama Güvenliği	Parametrelili sorgular, WAF koruması	DVWA'da SQL Injection ile DB bilgileri sızdırıldı	YÜKSEK
Patch Yönetimi	Kritik yamalar zamanında uygulanmalı	EternalBlue engellendi (MS17-010 yamalı)	DÜŞÜK
SIEM İzleme	Tüm kritik olaylar loglanmalı ve korele edilmeli	11 saldırı fazından 10'u SIEM'de tespit edildi (Level 6-14)	DÜŞÜK

OLAY SONRASI FAALİYETLER VE ÖNERİLER

NIST SP 800-61'in "Post-Incident Activity" fazına karşılık gelen bu bölüm, olaydan çıkarılan dersleri ilgili endüstri çerçevelerine (NIST CSF 2.0) eşleştirir.

#	Öneri	NIST CSF Fonksiyonu	Çerçeve Referansı	Öncelik
1	LSASS RunAsPPL / LSA Protection etkinleştirilmeli	Protect	NIST CSF PR.PT	YÜKSEK
2	SMB Signing zorunlu kılınmalı, SMBv1 devre dışı bırakılmalı	Protect	NIST CSF PR.AC	KRİTİK
3	Parola politikası (min. uzunluk + karmaşıklık) tüm hesaplarda uygulanmalı	Protect	NIST CSF PR.AC	KRİTİK
4	Sysmon Event ID 10 ile LSASS erişim izleme genişletilmeli	Detect	NIST CSF DE.CM	YÜKSEK
5	FIM ve DLP katmanları eklenerek host-dışı işlemler (offline crack, dosya çıkışı) izlenmeli	Detect	NIST CSF DE.CM	ORTA
6	DVWA/web katmanında WAF ve parametrelili sorgu zorunluluğu getirilmeli	Protect	NIST CSF PR.DS	YÜKSEK
7	Olay sonrası playbook'lar (Pth, SQLi, backdoor exploit) SOC prosedürlerine eklenmeli	Respond / Recover	NIST SP 800-61	ORTA
8	Tüm ayrıcalıklı hesaplar için MFA pratikte de zorunlu hale gelmeli.	Protect	NIST CSF PR.DS	YÜKSEK
9	Windows GPO ile 5 Başarısız Deneme = 30 dk hesap kilitleme uygulanmalı.	Protect	NIST CSF PR.AC	YÜKSEK

SOC GÖRÜNÜRLÜK ÖZETİ VE IOC LİSTESİ

SOC Visibility Summary & Indicators of Compromise

Wazuh + Suricata ikilisi, saldırı zincirinin hayati kritik adımlarını kaçırmamıştır. Keşiften PsExec'e, SQL Injection'dan vsftpd backdoor'a kadar tüm aktiviteler loglanmış ve doğru MITRE ATT&CK etiketleriyle sınıflandırılmıştır. Tek anlamlı görünürlük boşluğu, host dışında gerçekleştirilen offline hash kırma işlemidir ve FIM/DLP katmanlarıyla kapatılması önerilmektedir.

Indicators of Compromise (IOC)

Tür	Değer	Açıklama
IP - Saldırgan	192.168.1.75	Kali Linux saldırı kaynağı
IP - Hedef (Windows)	192.168.1.95	DESKTOP-ME7E039, Windows 10
IP - Hedef (Linux)	192.168.1.93	Metasploitable 2
Host - SIEM Sunucu	192.168.1.50	Wazuh SIEM Central Manager
Host - NIDS Sensör	192.168.1.46	Suricata IDS / Wazuh Agent
Kimlik Bilgisi	Administrator:1234567	Brute-force ile elde edilen zayıf parola
Kimlik Bilgisi	msfadmin:msfadmin, sys:batman, klog:123456789	Metasploitable 2 varsayılan/zayıf hesaplar
CVE	CVE-2011-2523	vsftpd 2.3.4 backdoor
Servis Portu	6200/tcp	vsftpd backdoor shell portu
Wazuh Rule	100080, 100082, 100026, 100047, 100050, 100051	Olayla ilişkili özel/varsayılan kural setleri

Referans Çerçeveler

- NIST SP 800-61 Rev.3:** Computer Security Incident Handling Guide — olay müdahale yaşam döngüsü.
- MITRE ATT&CK v15:** Reconnaissance, Initial Access, Credential Access, Lateral Movement, Exfiltration taktik/teknik eşlemesi.
- NIST CSF Cybersecurity Framework 2.0:** Identify / Protect / Detect / Respond / Recover fonksiyonlarına göre öneri eşlemesi.

Bu rapor bir SOC lab simülasyonu kapsamında hazırlanmıştır; TLP: CLEAR sınıflandırması ile paylaşılabılır.